

Cybersecurity and Privacy Regulations

Modes of Learning

For this module, the following modes of learning will be used:

- Interactive Module
- Textbook Readings
- Online Quizzes

Introduction

Understanding the Canadian cybersecurity landscape involves unraveling a web of legal and regulatory, and advisory documents. It is critical for organizations to understand this regulatory framework to protect sensitive data and preserve legal, financial, operational and reputational interests.

As you begin this module, please refer to the timeline and make note of any assessments or important dates. If you have any questions, ask your instructor.

Learning Outcomes

Upon completion of this module, you will be able to:

1. Examine cybersecurity legislation in Canada.

Key Terms & Concepts

Listed below are some important key terms and concepts within this module.

- CASL
- Digital Privacy Act
- Criminal Code of Canada
- PIPEDA

Cybersecurity Legislation in Canada

Canada's legislative and regulatory cybersecurity framework consists of Canada's Anti-Spam Legislation (CASL), the Criminal Code of Canada, the Personal Information Protection and Electronic Documents Act (PIPEDA), and the Digital Privacy Act.

The three government agencies responsible for enforcing the legislation and regulatory framework detailed above are the following:

1. The Canadian Radio-television and Telecommunications Commission (CRTC), which issues administrative monetary penalties (fines) for violations of CASL.
2. The Competition Bureau, which seeks administrative monetary penalties or criminal sanctions under the Competition Act.
3. The Office of the Privacy Commissioner of Canada (OPCC), which exercises new powers under the amended PIPEDA.

Canada's Anti-Spam Legislation (CASL)

CASL came into effect on July 1, 2014. CASL is similar to the United States' Federal Privacy Act in many respects and establishes rules for sending commercial electronic messages and installing computer programs. CASL prohibits:

- a. Sending commercial electronic messages without the recipient's permission, including messages to email addresses and social networking accounts and text messages to cell phones.
- b. Altering transmission data in an electronic message, resulting in a message being delivered to a different destination without express consent.
- c. Installing computer programs without the express consent of the owner of the computer system or its agent.
- d. Using false or misleading representations online in the promotion of products or services.
- e. Violating federal law (e.g. the Criminal Code of Canada) by accessing personal information without authorization through a computer system.
- f. Collecting electronic addresses by the use of computer programs or the use of such addresses, without permission.

Canada's Criminal Code

Canada's Criminal Code also contains provisions that prohibit cybercrime-related activities.

The Code sets out the following offences:

- a. Using a device to willfully intercept private communications without the express or implied consent of the originators or intended recipients.
- b. Fraudulently intercepting the function of a computer system.

On March 10, 2015, the Protecting Canadians from Online Crime Act came into force, amending the Criminal Code, the Canada Evidence Act, the Competition Act and the Mutual Legal Assistance in Criminal Matters Act. This legislation gives law enforcement agencies new, specialized investigative powers to help them act against child sexual exploitation online and disrupt online organized criminal activity. The legislation also gives police wide discretion to search Canadians' personal information and stored data.

Personal Information Protection and Electronic Document Act (PIPEDA)

Several statutes require organizations to protect personal information in their possession or control. PIPEDA is one such statute.

Amended by the Digital Privacy Act, which received Royal Assent in June 2015, PIPEDA applies to federally regulated organizations such as banks and telecommunications companies; PIPEDA protects personal information collected, used or disclosed in the course of commercial activities in jurisdictions that lack substantially similar legislation.

While many amendments came into force upon Royal Assent, it is anticipated that provisions relating to breaches of security safeguards (which generally include incidents of data breaches) will come into force in 2018. These changes include mandatory data breach notification requirements under section 10.1 of PIPEDA, where an organization reasonably believes that a breach of its security measures creates "a real

risk of significant harm to an individual.” Organizations are required to notify the OPCC and all affected individuals of a breach of security safeguards.

Some provinces have privacy legislation deemed “substantially similar” to PIPEDA. In some cases, that legislation applies instead of PIPEDA.

British Columbia, Alberta, and Quebec have their own private sector privacy laws recognized as “substantially similar” to PIPEDA. Ontario, New Brunswick and Newfoundland and Labrador have privacy legislation that applies to health information; the legislation has been declared substantially similar to PIPEDA with respect to health information custodians.

PIPEDA voluntary breach notifications – by industry sector and type of incident (January 1, 2015 – March 31, 2016)

Sector	Incident type			Total incidents per sector	% of total incidents
	Accidental Disclosure	Loss	Theft and Unauthorized access		
Accommodations			2	2	2%
Entertainment	1		1	2	2%
Financial	17	1	13	31	27%
Health	6		2	8	7%
Government			1	1	1%
Insurance	1		4	5	4%
Internet			3	3	3%
Not for profit organizations	3		4	7	6%
Other Sectors	1		10	11	10%
Sales/Retail	2	1	16	19	17%
Services	4	2	8	14	12%
Telecommunications	7		2	9	8%
Transportation	1		2	3	3%
Grand Total	43	4	68	115	100%

PIPEDA contains several provisions relevant to cybersecurity and protection of data. These include:

1. Schedule 1 provides that organizations are responsible for personal information under their control and must designate an individual or individuals to be accountable for compliance with the principles set out in Schedule 1.
2. Personal information must be protected by security safeguards that are appropriate for the sensitivity of the information.

3. The security safeguards must protect personal information against loss or theft, as well as unauthorized access, disclosure, copying, use or modification. Organizations must protect personal information regardless of its format or medium.
4. The nature of the safeguards will vary, depending on the sensitivity of the information collected; the amount, distribution and formation of the information; and the method of storage. Highly sensitive information should be safeguarded by a higher level of protection than less sensitive information.
5. Organizations must be open about their policies and practices for managing personal information. Individuals must be able to acquire information about an organization's policies and practices without unreasonable effort. This information must be made available in a form that is generally understandable.
6. An individual must be able to address a challenge concerning compliance with the above principles to the designated individual or individuals accountable for the organization's compliance.

Digital Privacy Act

Where notice is given to affected individuals, the Digital Privacy Act requires organizations to notify other organizations, such as government institutions and credit bureaus, as soon as feasible, if the notifying organization believes that the other organizations can reduce risks or mitigate harm.

Module Summary

In this module you have learned:

1. The Canadian cybersecurity regulatory space by providing a high-level overview of the legislative frameworks and policies that help organizations protect their networks and personal information.
2. The Canadian government and private organizations have made significant progress in creating a holistic and cooperative strategy to mitigate the risk of cybersecurity breaches.
3. Organizations should carefully and regularly review their existing cybersecurity policies and procedures, to ensure that they comply with existing and upcoming laws and regulations.

Knowledge Check

The following questions provide an opportunity for you to see what you remember and understand so far. Answer the questions to the best of your ability.

1. **CASL establishes rules for sending commercial electronic messages and installing computer programs.**
 - a. True
 - b. False
2. **Canada's legislative and regulatory framework regarding cybersecurity is composed of:**
 - a. Canada's Anti-Spam Legislation (CASL)
 - b. Criminal Code of Canada
 - c. Personal Information Protection and Electronic Document Act (PIPEDA)
 - d. Digital Privacy Act
 - e. All of the above

3. CASL prohibits the collection of electronic addresses by the use of computer programs, or the use of such addresses, without permission.
 - a. True
 - b. False
4. Canada's Criminal Code does not have specific provisions that prohibit cybercrime-related activities. Instead, it broadly prohibits cybercrime-related activities.
 - a. True
 - b. False
5. PIPEDA is statute that applies to federally regulated organizations.
 - a. True
 - b. False
6. PIPEDA has mandatory data breach notification requirements that are expected to come into force.
 - a. True
 - b. False
7. Where notice is given to affected individuals, the Digital Privacy Act will require organizations to notify other organizations.
 - a. True
 - b. False

Answers:

1. True
2. TBD
3. True
4. The answer is false because the code sets out the following offences: Using a device to willfully intercept a private communication without the express or implied consent of the originators or intended recipient and fraudulently intercepting the function of a computer system.
5. True
6. True
7. True

You have completed: Cybersecurity and Privacy Regulations

Remember to check the timeline before you proceed to the next module to ensure you have completed any assignments as required. Check with your instructor if you have any questions.